Guida alla migrazione dei controlli per il Framework Nazionale per la Cybersecurity e la Data Protection

CIS-Sapienza
Research Center of Cyber Intelligence and Information Security
Sapienza Università di Roma

CINI Cybersecurity National Lab
Consorzio Interuniversitario Nazionale per l'Informatica

Versione 1.0
Giugno 2026



Creative Commons License. This work is licensed under a Creative Commons Attribution 4.0 International License (http://creativecommons.org/licenses/by/4.0/).

Titolo: Guida alla migrazione dei controlli per il Framework Nazionale per la Cybersecurity e la Data Protection
Distribuito online – http://www.cybersecurityframework.it

Giugno 2026

Realizzato da:





Autori in ordine alfabetico:

Marco Angelini
Maria Patrizia Carello
Daniele Impagliazzo
Leonardo Querzoni

Indice dei contenuti

1 Introduzione 5

2 Guida al processo di migrazione 7

3 Confronto Crosswalk NIST 17

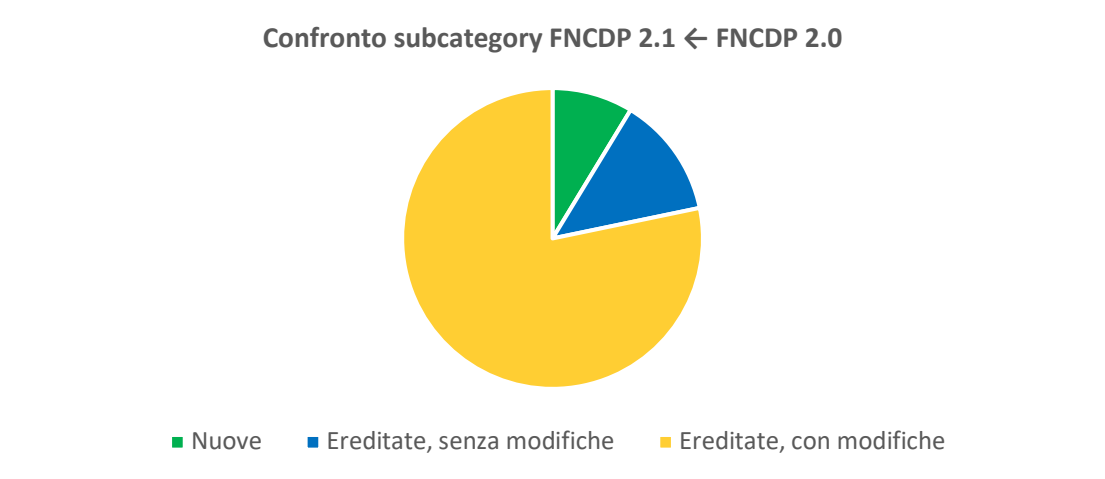
Appendice A. Metodologia 30

1 Introduzione

Nel panorama odierno delle minacce cibernetiche, la capacità di un'organizzazione di gestire in modo strutturato e resiliente i propri asset informativi e i dati personali è un fattore critico di sopravvivenza e competitività. In questo contesto, l'adozione di un framework di governance della cybersecurity non è più solo un'opzione di compliance, ma un pilastro fondamentale per garantire la continuità operativa e la fiducia degli stakeholder.

In Italia, il Framework Nazionale per la Cybersecurity e la Data Protection (FNCDP) si pone come il punto di riferimento per l'implementazione di standard di sicurezza e protezione dei dati, coerentemente con le esigenze del tessuto industriale e regolatorio nazionale.

L'evoluzione tecnologica e il mutamento del panorama delle minacce richiedono un aggiornamento costante dei modelli di riferimento. Per tale ragione, il passaggio dalla versione 2.0[1] alla versione 2.1[2] del FNCDP è stato guidato dalla necessità di allineare il *core* del framework nazionale al nuovo NIST Cybersecurity Framework 2.0[3]. Tale aggiornamento non rappresenta una mera revisione formale, ma un cambiamento strutturale profondo: l'adozione del nuovo core NIST introduce la nuova *function* Govern, ridefinisce le *category* e modifica la granularità delle *subcategory*, rendendo necessario un adeguamento completo di tutti i profili di sicurezza e dei controlli di sicurezza precedentemente associati alla versione 2.0 del FNCDP. In particolare, delle 115 subcategory del core del FNCDP 2.1, solo 15 sono rimaste fondamentalmente invariate rispetto alla precedente versione 2.0, 10 sono state aggiunte, e 90 derivano da subcategory della precedente versione con modifiche di diversa entità ed impatto.



[1] Framework Nazionale per la Cybersecurity e la Data Protection, Ed. 2019 (V2.0). Framework Core https://www.cybersecurityframework.it/sites/default/files/framework2/Framework_v2.0_core_ITA.xlsx

[2] Framework Nazionale per la Cybersecurity e la Data Protection, Ed. 2025 (V2.1). Framework Core https://www.cybersecurityframework.it/sites/default/files/framework2/FNCDP_-_Edizione_2025_v2.1_-_Core.xlsx

[3] NIST Cybersecurity Framework 2.0, https://www.nist.gov/cyberframework#csf-2-0

La migrazione tra le due versioni presenta, pertanto, complessità tecniche non trascurabili che si traducono in rischi significativi, tra cui:

- **Perdita di tracciabilità**: il rischio di non riuscire a trasferire correttamente i controlli esistenti sulle nuove subcategory;
- **Gap di copertura**: l'eventualità di trascurare i nuovi requisiti di governance e le modifiche strutturali del core;
- **Inconsistenza dei dati**: la possibilità di generare asimmetrie informative durante l'adeguamento dei profili target.

Gestire questa transizione senza una metodologia rigorosa espone l'Organizzazione a una visione incompleta o distorta del proprio livello di maturità e a un potenziale indebolimento della postura di sicurezza.

Per mitigare tali rischi, il presente documento introduce una metodologia sistematica di analisi e migrazione. L'obiettivo è fornire alle Organizzazioni un percorso rigoroso, basato su fasi iterative, per identificare i gap tra le versioni e gestire il trasferimento dei controlli in modo rigoroso. Il contributo principale di questo lavoro risiede nella fornitura di strumenti di supporto operativi, in particolare la *Matrice di Migrazione*[4], che contiene le cosiddette *Indicazioni per la Migrazione*: suggerimenti puntuali e raccomandazioni tecniche su come importare, modificare, unire o dividere i controlli di sicurezza attualmente esistenti per soddisfare pienamente i requisiti del FNCDP 2.1.

Per una consultazione efficace, il documento è strutturato come segue:

- Sezione 1 “Introduzione”: il testo di questa sezione.
- Sezione 2 “Guida al processo di migrazione”: fornisce le istruzioni operative per applicare le Indicazioni per la migrazione ai propri inventari di controlli.
- Sezione 3 “Confronto Crosswalk NIST”: descrive le differenze tra le relazioni tra subcategory riportate nella Matrice di Migrazione e quelle riportate nel Crosswalk rilasciato dal NIST.
- Appendice “Metodologia”: descrive il processo metodologico attraverso cui sono state definite le Indicazioni per la migrazione della Matrice di Migrazione.

Per una descrizione della terminologia e dei concetti tecnici riportati in questo documento, il lettore può fare riferimento al documento di presentazione del FNCDP.

[4] La Matrice di Migrazione è disponibile sul sito: https://www.cybersecurityframework.it

2 Guida al processo di migrazione

L'aggiornamento del Framework Nazionale per la Cybersecurity e la Data Protection con il passaggio del core dalla versione 2.0 a 2.1 ha comportato, come discusso nell'Introduzione, modifiche nella struttura e nel perimetro delle subcategory, con conseguenti impatti sulla definizione e associazione dei controlli di sicurezza precedentemente definiti.

L'allineamento dei processi di governo della cybersecurity, e delle relative misure tecnologiche, alla nuova versione del Framework non può essere quindi considerato come un'attività senza rischi, ma piuttosto richiede particolare attenzione e cura nella corretta revisione dei controlli di sicurezza.

Per garantire coerenza, tracciabilità e continuità rispetto alle attività di assessment, monitoraggio e reporting già in essere, è necessario un riesame sistematico dei controlli esistenti e della loro associazione alle nuove subcategory. Il processo di migrazione deve pertanto essere condotto in modo strutturato e tracciabile, evitando sia la perdita di requisiti di sicurezza sia l'introduzione di ridondanze non necessarie.

Questa sezione ha l'obiettivo di fornire una guida operativa a supporto del processo di migrazione dei controlli di sicurezza dalla versione 2.0 alla versione 2.1 del FNCDP.

Il processo di migrazione prevede come input la lista dei controlli di sicurezza esistenti, ciascuno associato a una o più subcategory del FNCDP 2.0, e produce come output una nuova lista di controlli di sicurezza, ciascuno mappato su una o più subcategory del FNCDP 2.1.

Il processo si articola in due fasi principali:

FASE 1 - Applicazione delle indicazioni per la migrazione: per ciascuna subcategory del FNCDP 2.1 applicare le indicazioni per la migrazione riportate nella Matrice di Migrazione[5]. Nel corso di questa attività, è necessario tenere traccia di ogni controllo, o parte di esso, che viene migrato nell'ambito della nuova subcategory.

FASE 2 - Verifica di completezza e coerenza: completata la migrazione di tutti i controlli nella Fase 1, verificare che nella lista originaria non rimangano controlli, o parti di essi, non oggetto di migrazione. Qualora vengano individuati controlli di questo tipo, è necessario valutare puntualmente ciascun caso, stabilendo se:

- possano essere eliminati, in quanto non più necessari o superati da altri controlli;
- debbano essere riconsiderati e rimappati su una o più category o subcategory del FNCDP 2.1, prestando particolare attenzione ad evitare duplicazioni o ridondanze rispetto ai controlli già migrati.

Nel seguito di questa sezione verranno forniti esempi di migrazione dei controlli di sicurezza, con l'obiettivo di illustrare in modo pratico l'applicazione della Matrice di Migrazione. Per ogni esempio vengono forniti:

1. la mappatura tra la subcategory del FNCDP 2.1 e quella del precedente FNCDP 2.0;
2. i controlli relativi al FNCDP 2.0 oggetto della migrazione;
3. le attività svolte per migrare i controlli nelle subcategory del FNCDP 2.1;
4. l'elenco finale dei controlli migrati.

[5] La Matrice di Migrazione è disponibile sul sito: https://www.cybersecurityframework.it

Nota informativa: gli esempi che seguono illustrano esclusivamente la modalità di applicazione della Matrice di Migrazione e non sono pertanto rappresentativi di una esaustiva implementazione delle subcategory analizzate. Si raccomanda a ciascuna Organizzazione di valutare l'adeguatezza dell'insieme di controlli previsti per ciascuna subcategory in coerenza con quanto necessario per il proprio contesto di riferimento.

Esempio 1: Mapping diretto

In questo primo esempio, andremo ad analizzare la migrazione dei controlli sulla nuova subcategory GV.RR-04 del FNCDP 2.1.

Sulla base delle relazioni riportate nella Matrice di Migrazione, la nuova subcategory è correlata unicamente alla subcategory PR.IP-11 del FNCDP 2.0.

FNCDP 2.1		FNCDP 2.0	
Sub ID (Dst)	**Subcategory (Dst)**	**Sub ID (Src)**	**Subcategory (Src)**
GV.RR-04	La cybersecurity è inclusa nelle pratiche delle risorse umane.	PR.IP-11	Le problematiche inerenti la cybersecurity sono incluse nei processi di gestione del personale (es: screening, deprovisioning).

Partendo dall'elenco completo dei controlli di sicurezza censiti dall'Organizzazione, si procede a individuare quelli attualmente mappati sulla subcategory PR.IP-11. Nel presente esempio troviamo quattro controlli associati a tale subcategory:

PR.IP-11	
Controllo 1	Nei processi di selezione del personale, sono verificate l'identità e le precedenti esperienze lavorative dei candidati
Controllo 2	Le competenze in materia di sicurezza informatica sono valutate come fattore nei processi di selezione del personale.
Controllo 3	Sono definiti e formalizzati in contratti e accordi individuali gli obblighi in materia di sicurezza informatica per tutto il personale.
Controllo 4	Sono definite e formalizzate procedure per l'off-boarding del personale, ivi inclusa la restituzione degli asset.

Attività di migrazione: azioni svolte

In conformità alle indicazioni riportate nella Matrice di Migrazione, l'aggiornamento della mappatura prevede le seguenti attività:

#	Indicazioni per la migrazione	Azioni svolte
1	Importare da PR.IP-11 tutti i controlli.	**Controllo 1, Controllo 2, Controllo 3 e Controllo 4** importati da PR.IP-11 a GV.RR-04.
2	Effettuare una revisione dell'insieme dei controlli previsti per la subcategory, valutando, in funzione del contesto e del profilo target dell'Organizzazione, eventuali modifiche e/o integrazioni	Analizzato l'insieme dei controlli importati, in base al contesto dell'Organizzazione, non appaiono necessarie ulteriori modifiche.

Seguendo le indicazioni del passo 1, i controlli previsti per PR.IP-11 possono essere importati nella subcategory GV.RR-04. Seguendo le indicazioni del passo 2, viene valutato che, in base al contesto dell'Organizzazione, non sono necessarie ulteriori modifiche all'insieme dei controlli previsti per GV.RR-04.

Al termine del processo di migrazione, saranno pertanto associati alla subcategory GV.RR-04 i seguenti controlli:

GV.RR-04	
Controllo 1	Nei processi di selezione del personale, sono verificate l'identità e le precedenti esperienze lavorative dei candidati
Controllo 2	Le competenze in materia di sicurezza informatica sono valutate come fattore nei processi di selezione del personale.
Controllo 3	Sono definiti e formalizzati in contratti e accordi individuali gli obblighi in materia di sicurezza informatica per tutto il personale.
Controllo 4	Sono definite e formalizzate procedure per l'off-boarding del personale, ivi inclusa la restituzione degli asset.

Esempio 2: Creazione di nuovi controlli ed unione di due controlli esistenti

Nel secondo esempio andremo ad analizzare la migrazione dei controlli sulla nuova subcategory ID.AM-03 del FNCDP 2.1.

In questo scenario, secondo le indicazioni fornite dalla Matrice di Migrazione, la subcategory della nuova versione del Framework raccoglie controlli che in precedenza erano distribuiti su più subcategory distinte:

FNCDP 2.1		FNCDP 2.0	
Sub ID (Dst)	**Subcategory (Dst)**	**Sub ID (Src)**	**Subcategory (Src)**
ID.AM-03	Sono mantenute le rappresentazioni delle comunicazioni di rete e dei flussi di dati di rete interni ed esterni, autorizzati dall'organizzazione.	ID.AM-3	I flussi di dati e comunicazioni inerenti l'organizzazione sono identificati.
		DE.AE-1	Sono definite, rese note e gestite delle pratiche di riferimento (c.d. baseline) inerenti l'utilizzo della rete ed i flussi informativi attesi per utenti e sistemi.

Partendo dall'elenco completo dei controlli di sicurezza censiti dall'organizzazione, si procede a individuare quelli attualmente mappati sulle subcategory sorgenti oggetto di migrazione:

ID.AM-3	
Controllo 1	Tutti i flussi di dati e di informazioni, inclusi quelli verso l'esterno e relativi al servizio cloud, sono identificati, censiti e registrati.
Controllo 2	L'Organizzazione mantiene rappresentazioni aggiornate delle comunicazioni di rete e dei flussi di dati, inclusi i flussi interni, esterni e verso servizi cloud, al fine di supportarne la gestione e la valutazione di sicurezza.

DE.AE-1	
Controllo 3	L'Organizzazione applica controlli sui flussi informativi, assicurando che il transito delle informazioni avvenga in conformità alle policy predefinite.

Attività di migrazione: azioni svolte

In conformità alle indicazioni riportate nella Matrice di Migrazione, l'aggiornamento della mappatura prevede le seguenti attività:

#	Indicazioni per la migrazione	Azioni svolte
1	Importare da ID.AM-3 tutti i controlli.	**Controllo 1** e **Controllo 2** importati da ID.AM-3 a ID.AM-03.
2	Importare da DE.AE-1 tutti i controlli.	**Controllo 3** importato da DE.AE-1 a ID.AM-03.
3	Se non già presenti e se richiesto dal contesto, valutare la definizione di nuovi controlli finalizzati a garantire che siano mantenute rappresentazioni delle comunicazioni di rete e dei flussi di dati di rete "interni ed esterni, autorizzati dall'organizzazione".	Analizzato l'insieme dei controlli importati durante i precedenti passi, è stata identificata l'assenza di un controllo che impone l'autorizzazione esplicita delle comunicazioni di rete e dei flussi di dati di rete. In base al contesto dell'Organizzazione, si ritiene opportuna la definizione di un nuovo controllo (**Controllo 4)**.
4	Se non già presenti e se richiesto dal contesto, valutare la definizione di nuovi controlli finalizzati all'aggiornamento periodico delle rappresentazioni delle comunicazioni di rete e dei flussi di dati di rete interni ed esterni, autorizzati dall'organizzazione	Analizzato l'insieme dei controlli importati durante i precedenti passi, in base al contesto dell'Organizzazione, non appaiono necessarie ulteriori modifiche.
5	Effettuare una revisione dell'insieme dei controlli previsti per la subcategory, valutando, in funzione del contesto e del profilo target dell'Organizzazione, eventuali modifiche e/o integrazioni	Analizzato l'insieme dei controlli importati durante i precedenti passi, il Controllo 2 parla di una documentazione strutturata e di un aggiornamento delle rappresentazioni rafforzando quanto già espresso dal Controllo 1 (che parla più nello specifico di identificazione, censimento e approvazione dei flussi). I due controlli possono pertanto essere uniti in un unico controllo (**Controllo 5)**. Il nuovo controllo sostituisce integralmente Controllo 1 e Controllo 2.

Riassumendo, a seguito dell'attività di migrazione, sono state pertanto effettuate le seguenti operazioni sui controlli di sicurezza:

1. **migrazione di un controllo esistente**, importato nella nuova subcategory senza modifiche rispetto al contenuto originario (Controllo 3);
2. **definizione di un nuovo controllo**, introdotto per soddisfare specifici requisiti previsti dalla nuova subcategory e non coperti dai controlli esistenti (Controllo 4);
3. **definizione di un nuovo controllo mediante unione di due controlli esistenti**: Controllo 1 e Controllo 2 risultano sovrapponibili e pertanto sono stati eliminati e sostituiti dal nuovo Controllo 5.

Alla nuova subcategory afferiranno pertanto i seguenti controlli:

ID.AM-03	
Controllo 3	L'Organizzazione applica controlli sui flussi informativi, assicurando che il transito delle informazioni avvenga in conformità alle policy predefinite.
Controllo 4	Le comunicazioni di rete e i flussi di dati interni ed esterni sono autorizzati da parte del responsabile della sicurezza.
Controllo 5	L'Organizzazione identifica, censisce e approva tutti i flussi di dati e di informazioni interni ed esterni, inclusi quelli verso servizi cloud, e mantiene rappresentazioni aggiornate delle comunicazioni di rete e dei flussi di dati autorizzati, al fine di supportare la gestione e la valutazione di sicurezza.

Esempio 3: Divisione di un controllo

In questo ultimo esempio, andremo ad analizzare la migrazione dei controlli sulla nuova subcategory PR.DS-01 del FNCDP 2.1.

In questo scenario, la subcategory della nuova versione del Framework raccoglie controlli che in precedenza erano distribuiti su più subcategory distinte.

FNCDP 2.1		FNCDP 2.0	
Sub ID (Dst)	**Subcategory (Dst)**	**Sub ID (Src)**	**Subcategory (Src)**
PR.DS-01	La riservatezza, l'integrità e la disponibilità dei dati a riposo (data-at-rest) sono protette.	PR.DS-1	I dati memorizzati sono protetti.
		PR.DS-5	Sono implementate tecniche di protezione (es. controllo di accesso) contro la sottrazione dei dati (data leak).
		PR.DS-6	Sono impiegati meccanismi di controllo dell'integrità dei dati per verificare l'autenticità di software, firmware e delle informazioni.
		PR.PT-2	I supporti di memorizzazione removibili sono protetti ed il loro uso è ristretto in accordo alle policy.

Partendo dall'elenco completo dei controlli di sicurezza censiti dall'Organizzazione, si individuano i controlli attualmente mappati sulle subcategory sorgenti oggetto di migrazione:

PR.DS-1	
Controllo 1	I file di log sono protetti utilizzando ACL restrittivi.
Controllo 2	I dati memorizzati sono cifrati.
Controllo 3	Gli accessi ai dati sono tracciati in file di log.

PR.DS-5	
Controllo 4	L'accesso alle informazioni critiche è consentito esclusivamente a utenti e applicazioni autorizzati, sulla base di policy di controllo degli accessi definite secondo il principio del minimo privilegio.

Controllo 5	L'integrità e l'autenticità dei dati in transito sono protette mediante l'utilizzo di protocolli sicuri.

PR.DS-6	
Controllo 5	L'integrità e l'autenticità dei dati in transito sono protette mediante l'utilizzo di protocolli sicuri.
Controllo 6	L'integrità dei dati a riposo e in transito è garantita mediante l'adozione di meccanismi di verifica e protezione contro modifiche non autorizzate, inclusi ad esempio controlli di integrità crittografici, firme digitali, checksum e sistemi di versioning.

PR.PT-2	
Controllo 7	I dati sui supporti di memorizzazione removibili sono cifrati.
Controllo 8	Viene disabilitata l'auto-esecuzione dei supporti di memorizzazione removibili, ed effettuata una scansione prima del loro utilizzo.

Attività di migrazione: azioni svolte

In conformità alle indicazioni riportate nella Matrice di Migrazione, l'aggiornamento della mappatura prevede le seguenti attività:

#	Indicazioni per la migrazione	Azioni svolte
1	Importare da PR.DS-1 tutti i controlli.	**Controllo 1**, **Controllo 2**, **Controllo 3** importati da PR.DS-1 a PR.DS-01.
2	Importare da PR.DS-5 i controlli finalizzati alla protezione delle proprietà di riservatezza, integrità e disponibilità dei dati a riposo (data-at-rest)	**Controllo 4** importato da PR.DS-5 a PR.DS-01. **Controllo 5** si riferisce esplicitamente ai dati in transito per cui non sarà importato in questa subcategory.
3	Importare da PR.DS-6 i controlli finalizzati alla protezione delle proprietà di riservatezza, integrità e disponibilità dei dati a riposo (data-at-rest) (considerare anche la protezione di proprietà quali la riservatezza e l'integrità di software	**Controllo 5** si riferisce esplicitamente ai dati in transito per cui non verrà importato in questa subcategory. **Controllo 6** fornisce indicazioni sulle tecniche da adottare per garantire l'integrità dei dati sia a riposo che in transito. Seguendo le indicazioni sarà

	e firmware)	importata solo la parte del controllo relativa ai dati a riposo.
4	Importare da PR.PT-2 i controlli finalizzati alla protezione delle proprietà di riservatezza, integrità e disponibilità dei dati a riposo (data-at-rest)	**Controllo 7** e **Controllo 8** importati da PR.PT-2 a PR.DS-01.
5	Se non già presenti e se richiesto dal contesto, definire nuovi controlli finalizzati a garantire che siano adeguatamente protette le proprietà di riservatezza, integrità e disponibilità dei dati a riposo (data-at-rest).	Analizzato l'insieme dei controlli importati durante i passi precedenti, è stata identificata l'assenza di controlli che garantiscano la disponibilità dei dati a riposo. In base al contesto dell'Organizzazione, si ritiene opportuna la definizione di un nuovo controllo (**Controllo 9**).
6	Effettuare una revisione dell'insieme dei controlli previsti per la subcategory, valutando, in funzione del contesto e del profilo target dell'Organizzazione, eventuali modifiche e/o integrazioni	Analizzato l'insieme dei controlli importati, in base al contesto dell'Organizzazione, non appaiono necessarie ulteriori modifiche.

Riassumendo, a seguito dell'attività di migrazione, sono state pertanto effettuate le seguenti operazioni sui controlli di sicurezza:

1. **importazione di controlli senza modifiche**: Controllo 1, Controllo 2, Controllo 3, Controllo 4, Controllo 7 e Controllo 8 sono stati importati nella nuova subcategory senza modifiche rispetto al contenuto originario;
2. **suddivisione di un controllo**: il Controllo 6 è stato modificato mantenendo esclusivamente la parte relativa all'integrità dei dati a riposo, in quanto l'integrità dei dati in transito non rientra nel perimetro della presente subcategory (sarà oggetto di migrazione nella subcategory PR.DS-2);
3. **definizione di un nuovo controllo**: il Controllo 9 è stato introdotto per soddisfare specifici requisiti previsti dalla nuova subcategory e non coperti dai controlli precedenti;

Alla nuova subcategory PR.DS-01 afferiranno pertanto i seguenti controlli:

PR.DS-01	
Controllo 1	I file di log sono protetti utilizzando ACL restrittivi.
Controllo 2	I dati memorizzati sono cifrati.
Controllo 3	Gli accessi ai dati sono tracciati in file di log.

Controllo 4	L'accesso alle informazioni critiche è consentito esclusivamente a utenti e applicazioni autorizzati, sulla base di policy di controllo degli accessi definite secondo il principio del minimo privilegio.
Controllo 6	L'integrità dei dati a riposo è garantita mediante l'adozione di meccanismi di verifica e protezione contro modifiche non autorizzate, inclusi ad esempio controlli di integrità crittografici, firme digitali, checksum e sistemi di versioning.
Controllo 7	I dati sui supporti di memorizzazione removibili sono cifrati.
Controllo 8	Viene disabilitata l'auto-esecuzione dei supporti di memorizzazione removibili, ed effettuata una scansione prima del loro utilizzo.
Controllo 9	Sono adottate misure per garantire la disponibilità dei dati a riposo, inclusi backup periodici, sistemi di memorizzazione ridondati e procedure di ripristino.

3 Confronto Crosswalk NIST

L'attività di analisi, condotta mediante l'applicazione della metodologia, ha consentito di individuare alcune possibili revisioni del Crosswalk rilasciato dal NIST[6], opportunamente contestualizzate per supportare la transizione dal FNCDP 2.0 al FNCDP 2.1.

La presente sezione illustra l'insieme di mappature aggiornate. In particolare, in ogni sottosezione viene illustrata la subcategory del FNCDP 2.1 per la quale sono state effettuate delle modifiche alle relazioni con il FNCDP 2.0, e a seguire le azioni intraprese sulle mappature con il relativo razionale. Gli interventi effettuati comprendono l'introduzione di nuovi mapping, la revisione di associazioni già esistenti e la rimozione di quelle non pienamente coerenti con i requisiti aggiornati del FNCDP 2.1.

Subcategory GV.OC-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
GV.OC-02	Gli stakeholder interni ed esterni sono noti e le loro esigenze e aspettative riguardo la gestione del rischio di cybersecurity sono comprese e considerate.

Per la subcategory GV.OC-02 del FNCDP 2.1, si è ritenuto opportuno rimuovere la seguente mappatura, in quanto per ID.GV-2 del FNCDP 2.0 sono state identificate delle relazioni più pertinenti.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
ID.GV-2 Il ruolo dell'organizzazione all'interno della filiera produttiva è identificato e reso noto.	Per ID.GV-2 del FNCDP 2.0 risultano più pertinenti le relazioni con GV.RR-02 e GV.SC-02 del FNCDP 2.1.	Rimossa

[6] Il documento "CSF 1.1 to 2.0 Core Transition Changes Overview" rilasciato dal NIST è disponibile su: https://www.nist.gov/document/csf-11-csf-20-core-transition-changes

Subcategory GV.OC-04

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
GV.OC-04	Gli obiettivi, le capacità e i servizi critici dai quali gli stakeholder dipendono o che si aspettano dall'organizzazione sono compresi e comunicati.

Sono state effettuate alcune integrazioni alle mappature al fine di garantire una più completa copertura dei requisiti. Le modifiche consentono di includere in modo più ampio gli aspetti relativi al ruolo dell'organizzazione, alle sue interdipendenze e alle aspettative degli stakeholder, sia in ingresso che in uscita.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
ID.BE-1 Il ruolo dell'organizzazione all'interno della filiera produttiva è identificato e reso noto.	ID.BE-1 è mappata dal NIST esclusivamente su GV.OC-05, garantendo la copertura delle dipendenze in ingresso (Organizzazione come downstream). Si è ritenuto opportuno aggiungere anche la relazione con GV.OC-04, per garantire la copertura dei requisiti anche per le dipendenze in uscita (Organizzazione come upstream).	Aggiunta
ID.BE-2 Il ruolo dell'organizzazione come infrastruttura critica e nel settore industriale di riferimento è identificato e reso noto.	Si ritiene opportuno aggiungere la mappatura di ID.BE-2 su GV.OC-04, in quanto tale subcategory integra quanto previsto da ID.BE-1, per cui è stata definita dal NIST una relazione con GV.OC-04.	Aggiunta

Subcategory GV.OC-05

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
GV.OC-05	I risultati, le capacità e i servizi dai quali l'organizzazione dipende sono compresi e comunicati.

È stata introdotta una nuova mappatura al fine di rafforzare la copertura dei requisiti relativi alla comprensione e comunicazione delle dipendenze dell'Organizzazione. L'integrazione

consente di includere elementi legati al contesto operativo e al ruolo dell'Organizzazione nel proprio ecosistema, contribuendo a una visione più completa delle interdipendenze.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
ID.BE-2 Il ruolo dell'organizzazione come infrastruttura critica e nel settore industriale di riferimento è identificato e reso noto.	Si ritiene opportuno aggiungere la mappatura di ID.BE-2 su GV.OC-05, in quanto tale subcategory integra e dettaglia i requisiti di ID.BE-1, per la quale è stata definita una relazione con GV.OC-05.	Aggiunta

Subcategory GV.PO-01

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
GV.PO-01	La politica per la gestione del rischio di cybersecurity è stabilita in base al contesto organizzativo, alla strategia di cybersecurity e alle priorità, ed è comunicata e applicata.

Sono state introdotte nuove mappature, relative a subcategory del FNCDP 2.0 con espliciti riferimenti alla definizione di policy di sicurezza all'interno dell'Organizzazione. L'integrazione consente di includere controlli che, pur appartenendo ad ambiti operativi differenti, risultano rilevanti per la definizione e il rispetto delle policy di sicurezza.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
PR.IP-5 Sono rispettate le policy ed i regolamenti relativi agli ambienti fisici in cui operano le risorse dell'organizzazione	La mappatura di PR.IP-5 è stata inserita esclusivamente con riferimento alla definizione di politiche di sicurezza informatica.	Aggiunta
PR.IP-6 I dati sono distrutti in conformità con le policy.	La mappatura di PR.IP-6 è stata inserita esclusivamente con riferimento alla definizione di politiche di sicurezza informatica.	Aggiunta
PR.PT-1 Esiste ed è attuata una policy per definire, implementare e revisionare i log dei sistemi	La mappatura di PR.PT-1 è stata inserita esclusivamente con riferimento alla definizione di politiche di sicurezza informatica.	Aggiunta

PR.PT-2 I supporti di memorizzazione rimovibili sono protetti ed il loro uso è ristretto in accordo alle policy.	La mappatura di PR.PT-2 è stata inserita esclusivamente con riferimento alla definizione di politiche di sicurezza informatica.	Aggiunta

Subcategory GV.SC-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
GV.SC-02	I ruoli e le responsabilità in materia di cybersecurity per fornitori, clienti e partner sono stabiliti, comunicati e coordinati internamente ed esternamente.

Si propone una nuova mappatura per ereditare i requisiti relativi al coordinamento di ruoli e responsabilità in ambito cybersecurity, considerando anche gli stakeholder esterni.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
ID.GV-2 Ruoli e responsabilità inerenti la cybersecurity sono coordinati ed allineati con i ruoli interni ed i partner esterni.	La nuova subcategory GV.SC-02 disciplina in modo esplicito la gestione dei ruoli di cybersecurity relativi alle terze parti, tema precedentemente integrato in ID.GV-2.	Aggiunta
PR.AT-3 Tutte le terze parti (es. fornitori, clienti, partner) comprendono i loro ruoli e responsabilità	Sebbene la precedente subcategory PR.AT-3 risulta esser parte della category Awareness and Training del FNCDP 2.0, si ritiene possibile che in relazione ad essa siano stati definiti controlli pertinenti ai fini di GV.SC-02; pertanto, si aggiunge tale mappatura.	Aggiunta

Subcategory ID.AM-07

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
ID.AM-07	Sono mantenuti gli inventari dei dati e dei relativi metadati per selezionati tipi di dati.

Si è deciso di rivedere la mappatura di ID.AM-3 in quanto già coerentemente coperta da un'associazione esistente.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
ID.AM-3 I flussi di dati e comunicazioni inerenti l'organizzazione sono identificati.	ID.AM-3 replica adeguatamente quanto previsto da ID.AM-03 del FNCDP 2.1; il NIST ha già riportato la relazione tra ID.AM-3 del CSF 1.1 e ID.AM-03 del CSF 2.0; pertanto, la mappatura su ID.AM-07 è stata rimossa.	Rimossa

Subcategory ID.IM-01

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
ID.IM-01	Sono identificati miglioramenti in esito alle valutazioni.

È stata introdotta una nuova mappatura al fine di estendere la copertura dei requisiti relativi all'identificazione dei miglioramenti derivanti dalle attività di valutazione dei processi di protezione.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
PR.IP-7 I processi di protezione sono sottoposti a miglioramenti.	PR.IP-7 risulta mappato dal NIST su ID.IM-03, riferito alle lessons learned, e all'intera categoria ID.IM. Considerata la natura più ampia di PR.IP-7 rispetto al solo ambito delle lezioni apprese, appare più coerente estendere la mappatura anche a ID.IM-01 che disciplina il miglioramento anche in esito alle valutazioni.	Aggiunta

Subcategory ID.IM-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
ID.IM-02	Sono identificati miglioramenti in esito ai test e alle esercitazioni di sicurezza, compresi quelli effettuati in coordinamento con i fornitori e le terze parti interessate.

È stata introdotta una nuova mappatura al fine di estendere la copertura dei requisiti relativi all'identificazione dei miglioramenti derivanti da attività di test ed esercitazioni di sicurezza, incluse quelle svolte in collaborazione con fornitori e terze parti.

FNCDP 2.0 **Subcategory (Src)**	**Razionale**	**Azioni**
PR.IP-7 I processi di protezione sono sottoposti a miglioramenti.	Attualmente PR.IP-7 risulta mappato dal NIST esclusivamente su ID.IM-03, riferito alle lessons learned, nonché in modo generico all'intera categoria ID.IM. Considerata la natura più ampia di PR.IP-7 rispetto al solo ambito delle lezioni apprese, appare più coerente estendere la mappatura anche a ID.IM-02 che disciplina il miglioramento anche in esito ai test ed alle esercitazioni di sicurezza.	Aggiunta

Subcategory ID.IM-03

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
ID.IM-03	Sono identificati miglioramenti dall'esecuzione di processi, procedure e attività operativi.

Per garantire maggiore coerenza con il requisito di identificazione strutturata dei miglioramenti derivanti dalle attività operative, sono state rimosse le associazioni non pienamente aderenti.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
RS.IM-2 Le strategie di risposta agli incidenti sono aggiornate.	La mappatura di RS.IM-2 proposta dal NIST su ID.IM-03 è stata rimossa poiché appare più appropriata la mappatura tra RS.IM-2 e ID.IM-04.	Rimossa
RC.IM-2 Le strategie di recupero sono aggiornate.	La mappatura di RC.IM-2 proposta dal NIST su ID.IM-03 è stata rimossa poiché appare più appropriata la mappatura tra RC.IM-2 e ID.IM-04.	Rimossa

Subcategory ID.IM-04

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
ID.IM-04	I piani di risposta agli incidenti e gli altri piani di cybersecurity che impattano le operazioni sono stabiliti, comunicati, mantenuti e migliorati.

L'analisi dei mapping esistenti ha evidenziato alcune lacune nella copertura dei requisiti di definizione, aggiornamento e miglioramento continuo dei piani di cybersecurity. Sono state pertanto introdotte integrazioni per rafforzare la coerenza e la tracciabilità dei controlli, nonché rimosse alcune associazioni non pienamente aderenti al perimetro della subcategory.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
PR.IP-12 Viene sviluppato e implementato un piano di gestione delle vulnerabilità.	Nelle mappature riportate dal NIST per PR.IP-12, si perde il requisito della definizione di un piano di gestione delle vulnerabilità. È stato pertanto aggiunto il mapping con ID.IM-04 (cfr. Implementation Examples del NIST CSF 2.0).	Aggiunta
RS.RP-1 Esiste un piano di risposta (response plan) e questo viene eseguito durante o dopo un incidente.	Nell'unica mappatura riportata per RS.RP-1, si perde il requisito della definizione di un piano di risposta. È stato pertanto aggiunto il mapping con ID.IM-04, che ne prevede formalmente la definizione.	Aggiunta

PR.PT-1 Esiste un piano di ripristino (recovery plan) e viene eseguito durante o dopo un incidente di cybersecurity.	Nelle mappature riportata per PR.PT-1, si perde il requisito della definizione di un piano di ripristino. È stato pertanto aggiunto il mapping con ID.IM-04, che ne prevede formalmente la definizione.	Aggiunta
RC.IM-2 Le strategie di recupero sono aggiornate.	ID.IM-04 richiede che i piani di risposta siano, tra le altre cose, "migliorati". Viene pertanto aggiunta la mappatura con la subcategory RC.IM-2 che parla genericamente di aggiornamento delle strategie di recupero.	Aggiunta
RS.IM-2 Le strategie di risposta agli incidenti sono aggiornate.	ID.IM-04 richiede che i piani di risposta siano, tra le altre cose, "migliorati". Viene pertanto aggiunta la mappatura con la subcategory RS.IM-2.	Aggiunta
RC.IM-1 I piani di ripristino tengono in considerazione le esperienze passate (lesson learned).	La mappatura di RC.IM-1 è stata rimossa in quanto appare più appropriata la mappatura tra RC.IM-1 e ID.IM-03.	Rimosso
RS.IM-1 I piani di risposta agli incidenti tengono in considerazione le esperienze passate (lesson learned).	La mappatura di RS.IM-1 è stata rimossa in quanto appare più appropriata la mappatura tra RS.IM-1 e ID.IM-03.	Rimossa

Subcategory PR.AT-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
PR.AT-02	Gli individui che ricoprono ruoli specializzati sono sensibilizzati e formati in modo da possedere le conoscenze e le competenze per svolgere i pertinenti compiti tenendo conto dei rischi di cybersecurity.

È stata introdotta una nuova mappatura al fine di includere i requisiti relativi alla formazione e alla consapevolezza del personale con ruoli specialistici nell'ambito della risposta agli incidenti. L'integrazione consente di estendere la copertura anche a competenze avanzate e specifiche, necessarie per lo svolgimento di attività in contesti di cybersecurity più complessi.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
RS.CO-1 Il personale conosce il proprio ruolo e le operazioni che deve svolgere in caso sia necessaria una risposta ad un incidente.	Attualmente RS.CO-1 risulta mappata dal NIST esclusivamente su PR.AT-01, la quale richiede competenze per lo svolgimento di compiti di carattere generale con attenzione ai rischi di cybersecurity. Poiché le attività di risposta agli incidenti costituiscono compiti specialistici e non generali, appare coerente aggiungere la mappatura su PR.AT-02.	Aggiunta

Subcategory PR.DS-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
PR.DS-02	La riservatezza, l'integrità e la disponibilità dei dati in transito (data-in-transit) sono protette.

Per questa subcategory è stato introdotto un nuovo mapping al fine di includere controlli che, seppur non esplicitamente riferiti ai dati in transito, contribuiscono alla verifica dell'integrità delle informazioni.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
PR.DS-6 Sono impiegati meccanismi di controllo dell'integrità dei dati per verificare l'autenticità di software, firmware e delle informazioni.	Viene aggiunta la mappatura di PR.DS-6 in quanto potrebbero derivare controlli relativamente all'integrità delle informazioni in transito.	Aggiunta

Subcategory PR.DS-10

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
PR.DS-10	La riservatezza, l'integrità e la disponibilità dei dati in uso (data-in-use) sono protette.

È stata introdotta una nuova mappatura in quanto i controlli relativi all'integrità dei dati possono contribuire alla protezione delle informazioni durante il loro utilizzo, rafforzando così la copertura dei requisiti associati alla protezione dei dati in uso.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
PR.DS-6 Sono impiegati meccanismi di controllo dell'integrità dei dati per verificare l'autenticità di software, firmware e delle informazioni.	Viene aggiunta la mappatura di PR.DS-6 in quanto potrebbero derivare controlli relativamente all'integrità delle informazioni in uso.	Aggiunta

Subcategory PR.PS-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
PR.PS-02	Il software è mantenuto, sostituito e rimosso in base al rischio.

È stata introdotta una nuova mappatura in quanto i controlli relativi alla precedente PR.MA-1 potrebbero essere di interesse anche ai fini di PR.PS-02.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
PR.MA-1 La manutenzione e la riparazione delle risorse e dei sistemi è eseguita e registrata con strumenti controllati ed autorizzati	Viene aggiunta la mappatura di PR.MA-1 in quanto da essa potevano essere stati previsti dalle Organizzazioni controlli relativamente alla manutenzione del software.	Aggiunta

Subcategory RS.CO-02

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
RS.CO-02	Gli stakeholder interni ed esterni sono informati degli incidenti.

Sono state riviste le mappature riguardanti la subcategory RS.CO-2 del FNCDP 2.0, relativa ai criteri di documentazione degli incidenti.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
RS.CO-2 Sono stabiliti dei criteri per documentare gli incidenti	Si ritiene opportuno rimuovere la mappatura tra RS.CO-02 del FNCDP 2.1 e RS.CO-2 del FNCDP 2.0, in quanto RS.CO-02 risulta relativa alla notifica degli incidenti a stakeholder interni ed esterni, misura non prevista da RS.CO-02.	Rimossa

Subcategory RC.RP-06

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
RC.RP-06	La conclusione del ripristino dell'incidente viene dichiarata sulla base di criteri definiti e la documentazione relativa all'incidente è completata.

Sono state riviste le mappature riguardanti la subcategory RS.CO-2 del FNCDP 2.0, relativa ai criteri di documentazione degli incidenti.

FNCDP 2.0 Subcategory (Src)	Razionale	Azioni
RS.CO-2 Sono stabiliti dei criteri per documentare gli incidenti	Seppure in misura limitata, RC.RP-06 risulta la subcategory del FNCDP 2.1 per cui esiste la relazione più adeguata con la subcategory RS.CO-2 del FNCDP 2.0.	Aggiunta

Subcategory RC.CO-04

FNCDP 2.1	
Sub ID (Dst)	**Subcategory (Dst)**
RC.CO-04	Gli aggiornamenti pubblici sul ripristino dagli incidenti sono condivisi utilizzando modalità e messaggi approvati.

Sono state riviste le mappature riguardanti la subcategory RS.CO-2 del FNCDP 2.0, relativa ai criteri di documentazione degli incidenti.

FNCDP 2.0 **Subcategory (Src)**	**Razionale**	**Azioni**
RS.CO-2 Sono stabiliti dei criteri per documentare gli incidenti	Si ritiene opportuno rimuovere la mappatura tra RC.CO-04 del FNCDP 2.1 e RS.CO-2 del FNCDP 2.0, in quanto RC.CO-04 risulta relativa alla condivisione, tramite modalità appropriate, degli aggiornamenti sul ripristino, misura non prevista da RS.CO-02.	Rimossa

Subcategory Data Protection

Rispetto al NIST Cybersecurity Framework 1.1, il Framework Nazionale per la Cybersecurity e la Data Protection 2.0 (edizione 2019) prevedeva nove subcategory aggiuntive, indirizzate a guidare la corretta gestione dei dati personali, con specifico riferimento alla sicurezza degli stessi. Tali subcategory sono state ereditate dal Framework Nazionale per la Cybersecurity e la Data Protection 2.1 (edizione 2025), pertanto si è reso necessario aggiungere – rispetto al Crosswalk del NIST – le seguenti mappature:

FNCDP 2.0	FNCDP 2.1	**Azioni**
Subcategory (Src)	**Subcategory (Dst)**	
DP-ID.AM-7 Sono definiti e resi noti ruoli e responsabilità inerenti al trattamento e la protezione dei dati personali per tutto il personale e per eventuali terze parti rilevanti (es. fornitori, clienti, partner)	**DP-GV.RR-05** I ruoli, le responsabilità e i correlati poteri inerenti al trattamento e la protezione dei dati personali sono stabiliti, comunicati, compresi e applicati.	Aggiunta
DP-ID.AM-8 I trattamenti di dati personali sono identificati e catalogati	**DP-ID.AM-09** I trattamenti di dati personali sono identificati e catalogati	Aggiunta

DP-ID.RA-11 Viene effettuata una valutazione di impatto sulla protezione dei dati personali.	**DP-ID.RA-7** Viene effettuata una valutazione di impatto sulla protezione dei dati personali.	Aggiunta
DP-ID.DM-1 Il ciclo di vita dei dati è definito e documentato	**DP-ID.DM-01** Il ciclo di vita dei dati è definito e documentato.	Aggiunta
DP-ID.DM-2 Sono definiti, implementati e documentati i processi riguardanti l'informazione dell'interessato in merito al trattamento dei dati	**DP-ID.DM-02** Sono definiti, implementati e documentati i processi riguardanti l'informazione dell'interessato in merito al trattamento dei dati.	Aggiunta
DP-ID.DM-3 Sono definiti, implementati e documentati i processi di raccolta e revoca del consenso dell'interessato al trattamento di dati	**DP-ID.DM-03** Sono definiti, implementati e documentati i processi di raccolta e revoca del consenso dell'interessato al trattamento di dati.	Aggiunta
DP-ID.DM-4 Sono definiti, implementati e documentati i processi per l'esercizio dei diritti (accesso, rettifica, cancellazione, ecc.) dell'interessato	**DP-ID.DM-04** Sono definiti, implementati e documentati i processi per l'esercizio dei diritti (accesso, rettifica, cancellazione, ecc.) dell'interessato.	Aggiunta
DP-ID.DM-5 Sono definiti, implementati e documentati i processi di trasferimento dei dati in ambito internazionale	**DP-ID.DM-05** Sono definiti, implementati e documentati i processi di trasferimento dei dati in ambito internazionale.	Aggiunta
DP-RS.CO-6 Gli incidenti che si configurano come violazioni di dati personali sono documentati ed eventualmente vengono informati le autorità di riferimento e gli interessati	**DP-RS.CO-06** Gli incidenti che si configurano come violazioni di dati personali sono documentati ed eventualmente vengono informate le autorità di riferimento e gli interessati.	Aggiunta

Appendice A. Metodologia

In quest'appendice viene illustrata la Metodologia di Analisi per la Migrazione, articolata in due fasi iterative, finalizzate all'individuazione dei gap esistenti tra differenti versioni di uno stesso Framework. L'applicazione di tale metodologia consente di elaborare la Matrice di Migrazione, in cui sono riportate indicazioni puntuali e raccomandazioni operative a supporto del processo di migrazione dei controlli di sicurezza.

A.1 Premessa ed obiettivi

Come base di riferimento per la mappatura tra il Framework Nazionale per la Cybersecurity e la Data Protection ed. 2019 (FNCDP 2.0) e il Framework Nazionale per la Cybersecurity e la Data Protection ed. 2025 (FNCDP 2.1) sono stati utilizzati[7]:

1. il Crosswalk[8] rilasciato dal NIST: illustra le 205 mappature esistenti tra il NIST CSF 1.1 e il NIST CSF 2.0;
2. il relativo documento CSF 1.1 to 2.0 Core Transition Changes[9] rilasciato dal NIST: integra il Crosswalk, e fornisce dettagli di alto livello relativamente alle mappature esistenti tra il NIST CSF 1.1 e il NIST CSF 2.0.

Analizzando le mappature riportate dal NIST nei documenti sopra menzionati, al livello di subcategory si riscontrano tre possibili casi generali:

1. la subcategory destinazione (CSF 2.0) deriva da una singola subcategory sorgente (CSF 1.1), la quale può a sua volta esser stata mappata su una o più subcategory destinazione;
2. la subcategory destinazione deriva da molteplici subcategory sorgente, ciascuna delle quali può essere stata mappata su una o più subcategory destinazione;
3. la subcategory destinazione introduce nuovi concetti e non deriva da subcategory della precedente versione del Framework.

Per quanto riguarda il razionale alla base delle mappature riportate nel Crosswalk, il NIST ha fornito alcune sintetiche indicazioni nella colonna "Noteworthy modifications" del documento Core Transition Changes.

L'**obiettivo** della presente attività è approfondire e specializzare ulteriormente tale razionale, fornendo al contempo alle Organizzazioni un documento operativo a supporto della migrazione dei controlli di sicurezza attualmente in essere ed allineati al FNCDP 2.0.

---

[7] Si ricorda l'equivalenza dei core – al netto di category, subcategory e informative references specifiche per la Data Protection– tra il FNCDP 2.0 e il NIST CSF 1.1 e tra il FNCDP 2.1 e il NIST CSF 2.0.

[8] CSF 1.1 to CSF 2.0 Crosswalk: https://csrc.nist.gov/csrc/media/Projects/olir/documents/submissions/CSFv1.1_to_CSFv2.0_CROSSWALK_20240220.xlsx

[9] CSF 1.1 to CSF 2.0 Core Transition Changes: https://www.nist.gov/document/csf-11-csf-20-core-transition-changes

A.2 Metodologia di Analisi per la Migrazione

La Metodologia di Analisi per la Migrazione riportata di seguito è stata derivata dalla concreta necessità della migrazione dal FNCDP 2.0 al FNCDP 2.1. Tuttavia, questa Metodologia adotta un approccio sistematico che può essere applicato per supportare la transizione tra qualsiasi versione del NIST Cybersecurity Framework (inclusi strumenti derivati e, eventualmente, ad ulteriori framework/standard di sicurezza), purché sia possibile stabilire una relazione tra gli obiettivi di sicurezza richiesti dalle subcategory dei Framework sorgente e destinazione.

Definizioni e assunzioni

La metodologia si basa sui seguenti concetti e relative definizioni: **Framework sorgente**, il Framework attualmente in uso presso l'Organizzazione, su cui sono mappati i controlli di sicurezza che devono essere migrati (negli esempi che seguono, il FNCDP 2.0); **Framework destinazione**, il nuovo Framework verso cui vuole migrare l'Organizzazione (negli esempi che seguono, il FNCDP 2.1); **Subcategory sorgente** (abbreviate con S), le subcategory del Framework sorgente a cui è applicata la Metodologia; **Subcategory destinazione** (abbreviate con D) le subcategory del Framework destinazione a cui è applicata la Metodologia.

Infine, è stato definito il concetto di **Requisito**: la suddivisione degli obiettivi di sicurezza richiesti da una subcategory in unità semantiche. Forniamo di seguito un esempio con la subcategory ID.RA-6 dal FNCDP 2.0:

Subcategory FNCDP 2.0	Requisiti
ID.RA-6: Le risposte al rischio sono identificate e prioritizzate	**Requisito #1**: Le risposte al rischio sono identificate. **Requisito #2**: Le risposte al rischio sono prioritizzate.

Il concetto di "Requisito" è lo strumento fondamentale della Metodologia, in quanto consente di specializzare ulteriormente le subcategory del Framework, suddividendone gli obiettivi di sicurezza, e fornire una visione più granulare del core stesso.

Presentiamo infine quattro assunzioni, adottate nella definizione ed analisi dei requisiti:

1. A una subcategory possono corrispondere uno o più requisiti;
2. Un requisito è assegnato esclusivamente a una singola subcategory;
3. A un requisito possono corrispondere uno o più controlli di sicurezza;
4. Un singolo controllo può soddisfare le richieste di più di un requisito.

Fase 1 – Identificazione requisiti e gap analysis

Input della Fase 1 è il Crosswalk del NIST - nella vista da Framework sorgente a Framework destinazione, il quale riporta le eventuali mappature che esistono tra ciascuna subcategory degli stessi. Si riporta, a titolo di esempio, un estratto del Crosswalk:

CSF 1.1 Sub ID	CSF 1.1 Sub Description	CSF 2.0 Sub ID	CSF 2.0 Sub Description
ID.GV-3	Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed.	GV.OC-03	Legal, regulatory, and contractual requirements regarding cybersecurity — including privacy and civil liberties obligations — are understood and managed.
ID.RM-1	Risk management processes are established, managed, and agreed to by organizational stakeholders.	GV.RM-01	Risk management objectives are established and agreed to by organizational stakeholders.
		GV.RM-06	A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated.
		GV.RR-03	Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies.

Fase 1 – Passo 1: Identificazione dei Requisiti sorgente

Obiettivo del primo passo previsto dalla metodologia è la definizione dei Requisiti della subcategory sorgente. Ad esempio:

Subcategory FNCDP 2.0	Requisiti sorgente (RS)
ID.RA-6: Le risposte al rischio sono identificate e prioritizzate	**RS1**: Le risposte al rischio sono identificate. **RS2**: Le risposte al rischio sono prioritizzate.

Fase 1 – Passo 2: Gap analysis

La Gap Analysis riporta le differenze che esistono tra i Requisiti di S e ciascuna delle D_n per le quali esiste una relazione con S. La Gap Analysis viene eseguita tra ciascuna coppia di subcategory $(S;D)$ per le quali esiste una mappatura; ciò vuol dire che se per una data S esiste una relazione sia con D_1 che con D_2, sono eseguite due distinte e indipendenti analisi, la prima tra $(S;D_1)$ e la seconda tra $(S;D_2)$. Quindi, nel caso in cui S sia mappata su più di una subcategory destinazione, es. D_1, D_2, D_3, questo passo – grazie alla prospettiva del Crosswalk da Framework sorgente a Framework destinazione – permette di chiarire la relazione che esiste tra S e ciascuna D_n, e identificare quali Requisiti di S devono essere migrati su D_1, D_2o D_3, in accordo con la seconda assunzione. Ad esempio:

S FNCDP 2.0	Requisiti sorgente	D FNCDP 2.1	Gap Analysis[10]
ID.RA-6: Sono identificate e prioritizzate le risposte al rischio	RS1: Sono identificate le risposte al rischio RS2: Sono prioritizzate le risposte al rischio	ID.RA-06: Le risposte al rischio sono scelte, prioritizzate, pianificate, monitorate e comunicate.	~RS1: "identificate" diventa "scelte" RS2: Invariato +R1: Le risposte al rischio devono essere pianificate +R2: Le risposte al rischio devono essere monitorate +R3: Le risposte al rischio devono essere comunicate

Fase 1 – Passo 3: Identificazione tipologia di output

Come discusso nell'Introduzione al presente documento e nella Premessa dell'Appendice A, l'allineamento del FNCDP al NIST CSF 2.0 ha comportato un'importante riorganizzazione del core. In particolare, ciascuna S può esser stata:

- semplicemente ereditata dal nuovo core, nella stessa category o collocata in una differente category o function;
- trasferita nel nuovo core con modifiche di diversa entità da analizzare, nella stessa category o collocata in una differente category o function;
- divisa tra molteplici D_n, appartenenti alla stessa o a diverse category o function.

Il terzo passo della Metodologia ha l'obiettivo di definire, formalizzare e catalogare tutte le possibili casistiche, andando quindi a identificare se S è stata mappata su zero, una o più D_n, essendo questo un fattore chiave nell'identificare se i Requisiti di S devono essere divisi tra più D_n o se tutti i requisiti di S possono essere integralmente ereditati da una singola D, in coerenza con la seconda assunzione.

Sono state formalizzate 7 tipologie di output teoricamente possibili per ciascuna coppia di subcategory $(S;D)$ per le quali esiste una mappatura, e l'applicazione della metodologia alla migrazione dal FNCDP 2.0 al FNCDP 2.1 ha confermato la validità di tale formalizzazione.

Nota: dalla prospettiva della mappatura da Framework sorgente a Framework destinazione, non consideriamo in questo passo se D deriva da una o più S_n; tale analisi sarà oggetto della Fase 2.

[10] Per la Gap Analysis, si usa la seguente notazione: RS_n per i Requisiti sorgente; "$\sim RS_n$", per minori revisioni ad un RS_n; "$+R_n$" per Requisiti aggiunti in D rispetto ad S; "$-RS_n$" per i RS_nin D rimossi rispetto ad S.

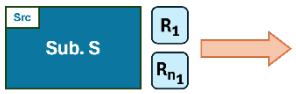
Di seguito sono presentate graficamente tutte le tipologie di output possibili:

Nessun output

S non è stata mappata nel Framework Destinazione

Tipologia 1 - Nessun Output

Requisiti di S persi nel Framework destinazione

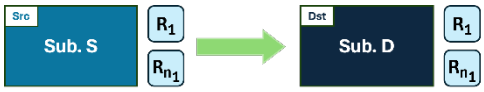


Output Singolo

S è stata mappata su una singola D

Tipologia 2 - Mappatura Completa

D ha gli stessi Requisiti di S



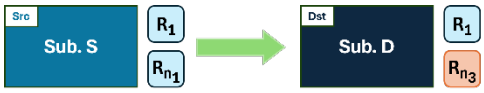
Tipologia 3 - Aggiunta Requisiti

D ha n_2 Requisiti aggiuntivi rispetto S



Tipologia 4 - Rimozione Requisiti

D ha n_3 Requisiti rimossi rispetto S



Tipologia 5 - Aggiunta e Rimozione Requisiti

D ha n_4 Requisiti rimossi rispetto S;

D ha n_5 Requisiti aggiuntivi rispetto S

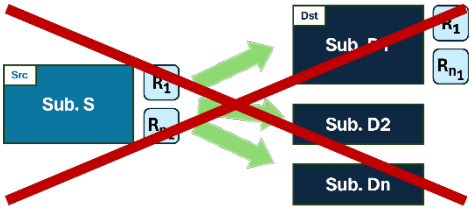


Output Multiplo

S è stata mappata su molteplici D_n

Tipologia 6 - Mappatura Completa

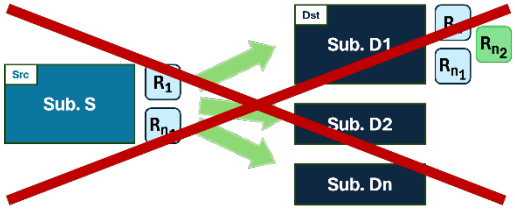
$D1$ ha gli stessi Requisiti di S



Caso teoricamente impossibile, non coerente con Assunzione 2

Tipologia 7 - Aggiunta Requisiti

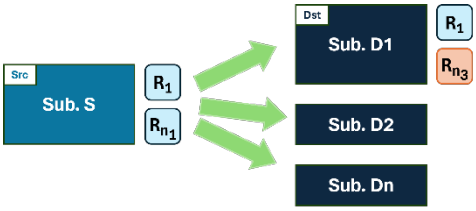
$D1$ ha n_2 Requisiti aggiuntivi rispetto S



Caso teoricamente impossibile, non coerente con Assunzione 2

Tipologia 8 - Rimozione Requisiti

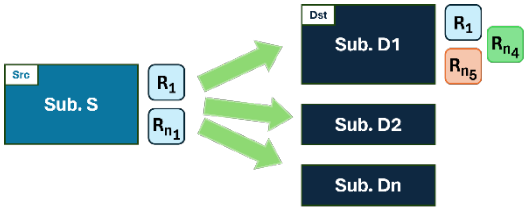
$D1$ ha n_3 Requisiti rimossi rispetto S



Tipologia 9 - Aggiunta e Rimozione Requisiti

$D1$ ha n_4 Requisiti aggiuntivi rispetto S;

$D1$ ha n_5 Requisiti rimossi rispetto S.



Fase 2 – Sintesi Matrice di Migrazione

Input della Fase 2 della Metodologia sono:

- il Crosswalk del NIST, nella vista da Framework destinazione a Framework sorgente (da FNCDP 2.1 a FNCDP 2.0 negli esempi);
- gli output della Fase 1: (a) Requisiti sorgente; (b) Gap Analysis; (c) Tipologia di Output.

Obiettivo della Fase 2 è quindi analizzare, sulla base di tutte le informazioni raccolte durante la Fase 1, il motivo della mappatura tra D e S_n, fornendo una spiegazione esaustiva della stessa e, infine, indicazioni puntuali per la migrazione dei controlli di sicurezza.

Fase 2 – Passo 1: Analisi di migrazione

Grazie agli input della Fase 2, possiamo completare le analisi, sfruttando una prospettiva che ci permette di analizzare per ciascuna D la relazione che esiste con le relative S_n. Esempio:

D FNCDP 2.1	S FNCDP 2.0	Analisi di migrazione
PR.DS-02: La riservatezza, l'integrità e la disponibilità dei dati in transito (data-in-transit) sono protette.	PR.DS-2: I dati sono protetti durante la trasmissione.	La mappatura tra PR.DS-02 e le precedenti subcategory deve essere intesa come limitata alla protezione dei dati in transito. Inoltre, PR.DS-02 specifica che devono essere protette le proprietà di riservatezza, integrità e disponibilità, mentre la precedente PR.DS-2 era più generica nelle richieste. Infine, PR.DS-5 e PR.DS-6 erano limitate solo ad alcuni ambiti della protezione dei dati in transito, rispetto alla più completa PR.DS-02.
	PR.DS-5: Sono implementate tecniche di protezione (es. controllo di accesso) contro la sottrazione dei dati (data leak).	
	PR.DS-6: Sono impiegati meccanismi di controllo dell'integrità dei dati per verificare l'autenticità di software, firmware e delle informazioni.	

Fase 2 – Passo 2: Tipologia di Input

Se nella Fase 1 – Passo 3 abbiamo categorizzato le possibili tipologie di Output che esistono tra S e D_n, coerentemente con la Metodologia e il cambio di prospettiva che è alla base della Fase 2 questo passo ha l'obiettivo di formalizzare le possibili tipologie di Input attese per ciascuna D del nuovo Framework. Si riscontrano tre casi generali:

1. D è una nuova subcategory, pertanto non deriva da nessuna S del precedente Framework
2. D deriva da una singola S
3. D deriva dall'unione di molteplici S_n

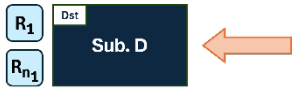
Complementando l'analisi con gli esiti della Fase 1 – Passo 3, si riscontrano tutte le possibili tipologie di output di seguito riportate:

Nessun input

D è una nuova subcategory del Framework destinazione

Tipologia 1 - Nessun input

Requisiti di D aggiunti nel Framework Destinazione



Input Singolo - Output Singolo

D deriva esclusivamente da S, la quale è a sua volta mappata esclusivamente su D

Tipologia 2 - Mappatura Completa

D ha gli stessi Requisiti di S



Tipologia 3 - Aggiunta Requisiti

D ha n_2 Requisiti aggiuntivi rispetto S



Tipologia 4 – Rimozione requisiti

D ha n_3 Requisiti rimossi rispetto S



Tipologia 5 - Aggiunta e Rimozione Requisiti

D ha n_4 Requisiti aggiuntivi rispetto S;
D ha n_5 Requisiti rimossi rispetto S

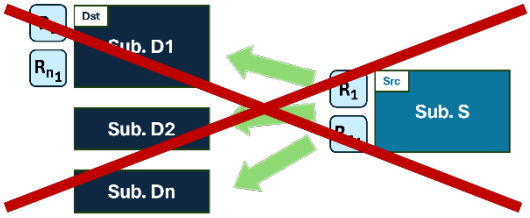


Input Singolo - Output Multiplo

D deriva esclusivamente da S, ma S è stata mappata su molteplici D_n

Tipologia 6 - Mappatura Completa

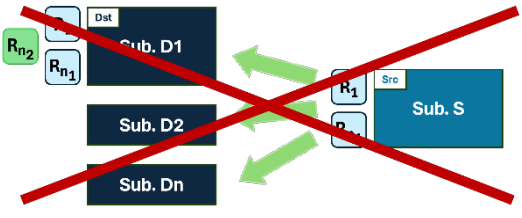
D1 ha gli stessi Requisiti di S



Caso teoricamente impossibile, non coerente con Assunzione 2

Tipologia 7 - Aggiunta Requisiti

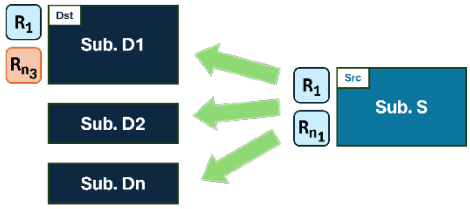
D1 ha n_2 Requisiti aggiuntivi rispetto S



Caso teoricamente impossibile, non coerente con Assunzione 2

Tipologia 8 – Rimozione requisiti

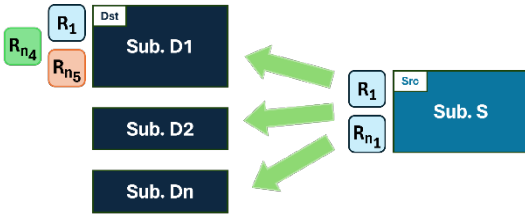
D1 ha n_3 Requisiti rimossi rispetto S



Tipologia 9 - Aggiunta e Rimozione Requisiti

D1 ha n_4 Requisiti aggiuntivi rispetto S;

D1 ha n_5 Requisiti rimossi rispetto S

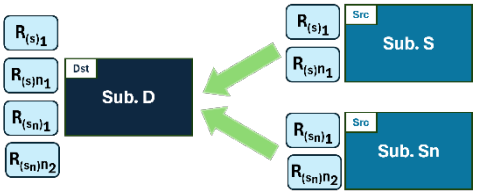


Input Mulitplo - Output Singolo

D deriva da molteplici S_n, ma ciascuna S_n è stata mappata esclusivamente con D

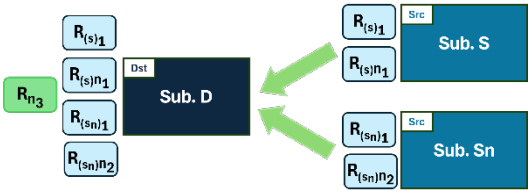
Tipologia 10 - Mappatura Completa

D ha gli stessi Requisiti delle S_n



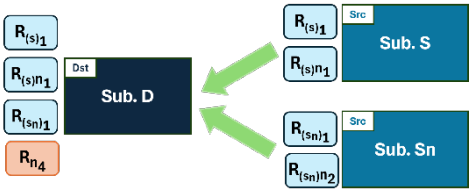
Tipologia 11 - Aggiunta Requisiti

D ha n_3 Requisiti aggiuntivi rispetto alle S_n



Tipologia 12 – Rimozione requisiti

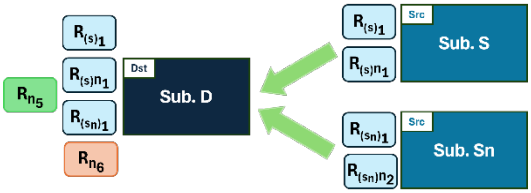
D ha n_4 Requisiti rimossi rispetto alle S_n



Tipologia 13 - Aggiunta e Rimozione Requisiti

D ha n_5 Requisiti aggiuntivi rispetto S_n;

D ha n_6 Requisiti rimossi rispetto S_n

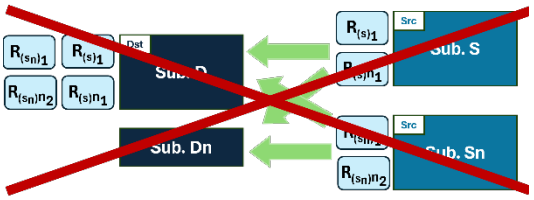


Input Multiplo - Output Multiplo

D deriva da molteplici S_n, e almeno una di tali S_n è stata mappata su molteplici D_n

Tipologia 14 - Mappatura Completa

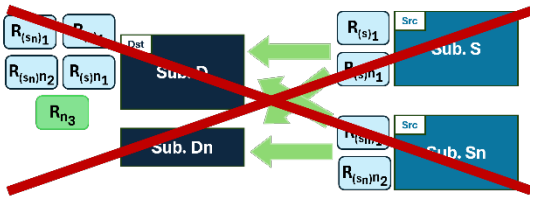
D ha gli stessi Requisiti di S_n



Caso teoricamente impossibile,
non coerente con Assunzione 2

Tipologia 15 - Aggiunta Requisiti

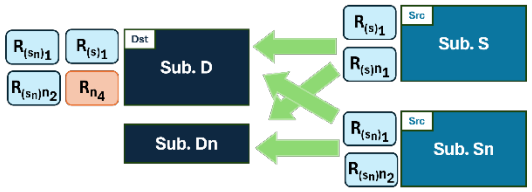
D ha n_3 Requisiti aggiuntivi rispetto S_n



Caso teoricamente impossibile,
non coerente con Assunzione 2

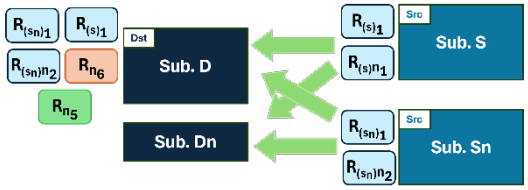
Tipologia 16 - Rimozione Requisiti

D ha n_4 Requisiti rimossi rispetto S_n



Tipologia 17 - Aggiunta e Rimozione Requisiti

D ha n_5 Requisiti aggiuntivi rispetto S_n;
D ha n_6 Requisiti rimossi rispetto S_n



Fase 2 – Passo 3: Indicazioni per la Migrazione

L'obiettivo della metodologia consiste nel fornire una sintesi chiara e strutturata di tutte le analisi svolte, identificando in modo puntuale il razionale alla base delle relazioni tra il Framework sorgente e destinazione, e produrre quindi infine l'Indicazione per la migrazione dei controlli di sicurezza: si tratta di un insieme di suggerimenti (un insieme per ciascuna subcategory del nuovo Framework) che sarà proposto alle Organizzazioni interessate ad effettuare la transizione dal Framework sorgente al Framework destinazione. Tali indicazioni riportano, per ciascuna D, i diversi passaggi che, se seguiti, consentono alle Organizzazioni di importare i controlli dalle S_n alle D_n. Si propone di seguito un esempio:

D FNCDP 2.1	**S FNCDP 2.0**
PR.DS-02: La riservatezza, l'integrità e la disponibilità dei dati in transito (data-in-transit) sono protette.	PR.DS-2: I dati sono protetti durante la trasmissione.
	PR.DS-5: Sono implementate tecniche di protezione (es. controllo di accesso) contro la sottrazione dei dati (data leak).
	PR.DS-6: Sono impiegati meccanismi di controllo dell'integrità dei dati per verificare l'autenticità di software, firmware e delle informazioni.
Indicazioni per la Migrazione	
1. Importare da PR.DS-2 tutti i controlli **2.** Importare da PR.DS-5 i controlli finalizzati alla protezione delle proprietà di riservatezza, integrità e disponibilità dei dati in transito (data-in-transit) **3.** Importare da PR.DS-6 i controlli finalizzati alla protezione delle proprietà di riservatezza, integrità e disponibilità dei dati in transito (data-in-transit) **4.** Se non già presenti e se richiesto dal contesto, definire nuovi controlli finalizzati a garantire che siano adeguatamente protette le proprietà di riservatezza, integrità e disponibilità dei dati in transito (data-in-transit). **5.** Effettuare una revisione dell'insieme dei controlli previsti per la subcategory, valutando eventuali modifiche, integrazioni o rimozioni, al fine di soddisfare pienamente i requisiti della subcategory.	

Output: Matrice di Migrazione

L'output dell'applicazione della Metodologia è la Matrice di Migrazione, che raccoglie le Indicazioni per la migrazione per ciascuna subcategory del Framework destinazione, assieme ed eventuali considerazioni di particolare interesse dell'Analisi di Migrazione presentata in Fase 2 – Passo 1. Le Organizzazioni potranno quindi migrare i controlli di sicurezza al nuovo Framework, seguendo la guida riportata nel presente documento.

A titolo esemplificativo dell'applicazione della Metodologia, la Matrice di Migrazione per supportare le Organizzazioni nella transizione dal FNCDP 2.0 al FNCDP 2.1 è disponibile sul sito: https://www.cybersecurityframework.it